SecureAccess — Implementação e Avaliação de um Sistema de Autenticação Multifator (MFA)

1st Miguel Bento
Nº101018
ISCTE
mvboe1@iscte-iul.pt

2nd Luís Lourenço
Nº110942
ISCTE
lcmlo@iscte-iul.pt

3rd Ricardo Ourelo
Nº120141
ISCTE
rcooo2@iscte-iul.pt

4th Josué da Glória
Nº134449
ISCTE
jlgas@iscte-iul.pt

***Resumo*—Este trabalho defende a criação de um sistema de Autenticação Multifator (MFA) para aumentar a segurança de autenticações em websites. Pretende-se provar, por meio de um caso prático de um protótipo feito em Flask (Python), que a junção de fatores de autenticação ("algo que o utilizador sabe" e "algo que o utilizador tem") previne ataques baseados no roubo de credenciais. Além da parte prática, o trabalho também incorpora uma revisão de literatura, que identifica as principais abordagens, desafios e boas práticas no uso de MFA em sistemas de informação. Assim, o objetivo é trazer uma perspetiva da teoria e da prática de MFA, revelando como uma solução simples, eficaz e essencial pode ajudar a reforçar a segurança.**

Palavras-chave: autenticação, multifator, login, segurança, cibersegurança

Glossário

Sigla	Descrição
AALs	Authenticator Assurance Levels
AI	Artificial Intelligence
BLE	Bluetooth Low Energy
CCS	Conference on Computer and Communications Security
EU	European Union
ENISA	European Union Agency for Cybersecurity
FIDO2	Fast Identity Online 2
GDPR	General Data Protection Regulation
ISO/IEC	International Organization for Standardization /
27001	International Electrotechnical Commission 27001
MFA	Multi-Factor Authentication
ML	Machine Learning
NFC	Near Field Communication
NIST	National Institute of Standards and Technology
PIPOC	Population Intervention Comparison Outcome Context
RSL	Systematic Literature Review
SIM	Subscriber Identity Module
SMS	Short Message Service
SP	Special Publication
TOTP	Time-based One-Time Password
WebAuthn	Web Authentication API
2FA	Two-Factor Authentication

I. Introdução

A. Contextualização e Motivação

Nos sistemas de informação modernos, a autenticação de utilizadores constitui um dos pilares fundamentais da segurança. Apesar dos avanços em criptografia, deteção de intrusões e proteção de redes, a maioria dos incidentes de segurança continua a ocorrer devido ao uso indevido ou comprometimento de credenciais. Diversos estudos indicam que mais de 80% das violações de segurança resultam do uso de palavras-passe fracas, reutilizadas ou obtidas através de técnicas de phishing [10]. Como sublinham Tran-Truong, Nguyen e Ngo [10], "a maioria dos incidentes de segurança em sistemas de pagamento digital ainda decorre de palavras-passe fracas ou reutilizadas e ataques de engenharia social, como phishing" (p. 2).

A autenticação multifator surge como uma resposta eficaz a esta vulnerabilidade, combinando diferentes categorias de fatores, algo que o utilizador sabe (ex.: palavra-passe), algo que o utilizador tem (ex.: token ou smartphone) e algo que o utilizador é (ex.: biometria). Segundo o NIST Special Publication 800-63B [9], a utilização de múltiplos fatores de autenticação permite atingir níveis superiores de garantia (Authenticator Assurance Levels – AALs) e reduzir de forma significativa o risco de acesso não autorizado, mesmo que um dos fatores seja comprometido.

A literatura académica mais recente reforça esta perspetiva, salientando que a MFA é atualmente uma das práticas mais eficazes e escaláveis de mitigação de riscos em ambientes digitais. No entanto, a sua adoção ainda enfrenta diversos desafios relacionados com usabilidade, custos de implementação e resistência dos utilizadores [10]. Estes fatores assumem particular relevância em contextos empresariais e financeiros, onde a segurança deve ser equilibrada com a conveniência e a experiência de utilização. Assim, compreender as abordagens, benefícios e limitações associadas à MFA é fundamental para conceber sistemas de autenticação mais seguros, confiáveis e adaptáveis à realidade tecnológica atual.

B. Visão Produto

O projeto, intitulado *SecureAccess – Autenticação Multifator (MFA)*, visa demonstrar e analisar a eficácia do MFA enquanto mecanismo de reforço da segurança em sistemas de autenticação web.

A visão central consiste em articular uma revisão sistemática da literatura com o desenvolvimento de um protótipo funcional em Flask (Python), demonstrando na prática a eficácia da MFA baseada em palavra-passe e código TOTP.

Desta forma, o projeto procura demonstrar, de forma concreta, como a combinação dos dois fatores referidos anteriormente aumenta substancialmente a resiliência de um sistema face a ataques comuns como *credential stuffing*, *phishing* ou *brute-force*.

C. Objetivos

Objetivo Geral

Conceber, investigar e apresentar uma solução de autenticação multifatorial (MFA) que demonstre o aumento de segurança em relação à autenticação tradicional unicamente com palavra passe.

Objetivos Específicos

- Investigar os trabalhos que registam a aplicação de MFA, os seus principais métodos, limitações e boas práticas delineadas pela comunidade científica;
- Construir um pequeno projeto de autenticação com palavra passe + TOTP (Time-based One-Time Password) com Flask;
- Analisar a efetividade e a usabilidade da solução implementada, compará-la com os resultados da pesquisa teórica;
- Comparar o desempenho e a usabilidade do sistema MFA desenvolvido com modelos de autenticação tradicionais;
- Apontar melhoramentos futuros e outras apostas como o uso de chaves FIDO2/WebAuthn ou biometria.

D. Metodologia

A metodologia utilizada divide-se em dois pontos fortes e que se complementam:

1) Vertente Teórica: Revisão Sistemática da Literatura: Parte teórica: Seguir o protocolo de Revisão Sistemática da Literatura (RSL) disponibilizado pelo professor, com a definição das perguntas de investigação, string de pesquisa, critérios de inclusão e exclusão, e interpretação dos dados recolhidos em bases de dados científicas (Scopus, IEEE Xplore, ScienceDirect e ACM Digital Library);

2) Vertente Prática: Desenvolvimento do Protótipo: Na perspetiva prática: Criação de uma aplicação do Flask que suporta MFA com TOTP, ilustrando o processo de autenticação em dois passos. O código foi escrito e testado de modo a evidenciar o funcionamento do segundo fator e a influência na proteção do acesso.

Esta dupla vertente permite uma ligação direta entre a teoria (estado da arte) e a prática (caso de estudo), proporcionando uma perspetiva global da eficácia e pertinência da MFA.

II. Metodologia da Revisão Sistemática

A. Contexto e Objetivos da Revisão Sistemática

A Revisão Sistemática da Literatura (RSL) pretende localizar, avaliar e integrar as principais investigações científicas sobre reforço da autenticação multifator, com enfoque nas técnicas, obstáculos, oportunidades e tendências de utilização.

A intenção principal é capturar o estado da arte nesta vertente, dando um sustentáculo teórico ao desenvolvimento do SecureAccess, alinhado com os mais recentes padrões de segurança digital [9].

Segundo o protocolo definido, a revisão seguiu um procedimento rigoroso que compreendeu a formulação dos problemas, a aplicação dos critérios de inclusão e exclusão e, por último, a extração e síntese da informação relevante.

Deste modo, esta revisão pretende dar resposta às questões de investigação formuladas, explorar a comunidade científica e perspetivar oportunidades de melhoria para aplicação no projeto SecureAccess.

B. Questões de Investigação e Orientação Metodológica

Questão 1: Que técnicas e fatores predominam em MFA (ex.: TOTP, SMS, biometria, FIDO2)?

Questão 2: Que métodos e fatores de autenticação são os que maior sucesso revelam na literatura científica e em que medida se aplicam a sistemas web atuais?

Questão 3: De que forma com a implementação de um segundo fator TOTP aumenta a segurança de um sistema de login tradicional baseado em password?

C. Estratégia de Pesquisa e Fontes de Informação Científica

A estratégia de pesquisa seguiu as fases estabelecidas no protocolo de Revisão Sistemática da Literatura, com base na técnica PIPOC (Population, Intervention, Comparison, Outcome e Context).

Neste caso, a população são os utilizadores e sistemas de autenticação digital, a intervenção é o recurso à MFA, a comparação realiza-se face à autenticação de fator único (SFA), o resultado pretendido é uma melhoria da segurança e da usabilidade, e o contexto são as aplicações e sistemas web.

Uma vez reunidos, os resultados foram selecionados por título e resumo e de seguida avaliados na sua totalidade, segundo a técnica Three, Pass Reading [6], para garantir um julgamento rigoroso e uniforme da pertinência de cada publicação.

A escolha final incluiu investigações que discutiam técnicas de MFA, comparações entre abordagens, problemas de usabilidade e casos de uso reais.

D. Ferramentas de Apoio e Gestão Bibliográfica

Com o objetivo de manter a organização e transparência do processo de revisão, recorreram-se a diversas ferramentas de suporte técnicas e bibliográficas.

A gestão das referências e das citações foi feita através da plataforma Mendeley, permitindo uniformizar as referências no formato IEEE e inserir citações numéricas de forma consistente ao longo do relatório.

Para a pesquisa e recolha dos diversos artigos usados para a elaboração deste relatório recorreram-se a ferramentas académicas como o Google Scholar, Scopus e Web of Science que permitiram o acesso completo dos artigos e a verificação cruzada das citações.

Estas ferramentas foram de grande ajuda para garantir a transparência e a consistência metodológica da Revisão Sistemática da Literatura apresentada neste relatório.

III. Estado da Arte

Nos últimos anos, a MFA evoluiu para modelos mais flexíveis e contextuais, alavancados pela progressão da inteligência artificial, do *machine learning* e das tecnologias mobile. Um exemplo pertinente disto é o trabalho de Aburbeian e Fernández-Veiga [1], que propuseram um *framework* de autenticação adaptativa para operações financeiras online, juntando a MFA com algoritmos de *machine learning* para inferir o risco de cada operação. Quando o sistema percebe que algo não bate certo, pede fatores adicionais de autenticação. Este modelo não só minimiza a fadiga do utilizador como é um bom exemplo da mudança de uma MFA rígida para uma abordagem baseada em risco, ajustando o nível de segurança ao contexto.

Ainda no domínio da segurança de acesso, Amft et al. [3] conduziram um estudo extensivo sobre os mecanismos de recuperação de contas em sistemas com MFA, analisando mais de 1.300 serviços online. Os autores chegaram à conclusão que, mesmo que a MFA fortaleça o login inicial, a maioria dos sistemas falha em garantir uma boa segurança durante o processo de recuperação, permitindo que se contorne a autenticação forte durante o processo de recuperação com requisitos fracos. Este estudo serve como um alerta para a importância de se pensar em fluxos de recuperação que não comprometam o processo de autenticação, bem como para não esquecermos as vulnerabilidades tanto de origem humana como técnica.

Outro contributo relevante surge da revisão sistemática de Podapati, Nigam e Das [7], que sintetiza o estado da arte em autenticação adaptativa e contínua em ambientes móveis. Os autores destacam o papel crescente da análise comportamental e contextual, como padrões de utilização, localização e sensores do dispositivo, na criação de sistemas de autenticação inteligentes e não intrusivos. Esta perspetiva reforça a tendência para a "autenticação invisível", em que o sistema avalia continuamente o risco sem exigir múltiplas interações explícitas do utilizador.

Por sua vez, Shukla, Varshney, Singh e Goel [8] exploraram uma abordagem *passwordless*, combinando biometria facial, proximidade física e comunicação *contactless* (NFC/BLE) para autenticação em dispositivos Android. O estudo demonstra que eliminar o fator de conhecimento (a palavra-passe) pode simplificar a experiência do utilizador e reduzir vulnerabilidades associadas à gestão de credenciais. Contudo, os autores alertam para os riscos de spoofing biométrico e para a necessidade de hardware compatível, fatores que ainda limitam a adoção generalizada deste modelo.

A. Tipos de Autenticação MFA

Dependendo da combinação de fatores de autenticação escolhidos, a MFA pode assumir diferentes formas. Por exemplo, a diretriz NIST SP 800-63B-4 [9] define três tipos principais de fatores: conhecimento (algo que o utilizador sabe), posse (algo que o utilizador tem) e inerência (algo que o utilizador é), conforme ilustrado na Figura 1.

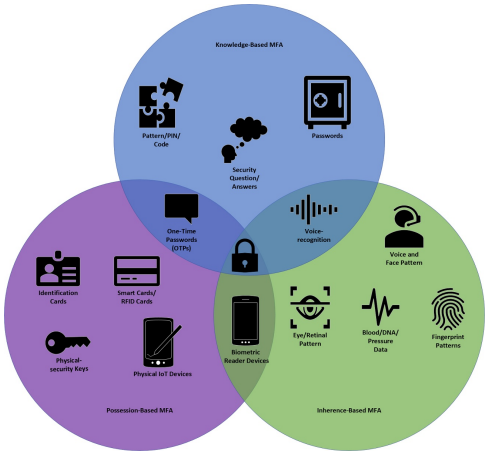

Figura 1. Diagrama Venn dos fatores em MFA.
Nota. Adaptado de *A review of multi-factor authentication in the Internet of Healthcare Things*, por T. Suleski, M. Ahmed, W. Yang e E. Wang, 2023, *Digital Health*, 9. https://journals.sagepub.com/doi/full/10.1177/20552076231177144.

A forma mais utilizada de MFA é conhecida como Autenticação de Dois Fatores (2FA), uma combinação de dois fatores diferentes. Normalmente, este modelo integra um fator de conhecimento, como uma senha ou PIN, com fatores de posse, como um código temporário enviado por SMS ou gerado por um aplicativo autenticador (TOTP) [5].

A Autenticação de Três Fatores (3FA) introduz um terceiro fator, normalmente considerado um fator inerente, como biometria (impressão digital, rosto, íris ou voz). Apesar de melhorar significativamente a segurança, este método é mais complexo em termos de tecnologia e custos de implementação [9].

A Autenticação Adaptativa (*Adaptive Authentication*), por outro lado, é mais dinâmica, pois ajusta os fatores necessários de acordo com o contexto de um utilizador. Podem existir variações como localização, endereço IP, dispositivo utilizado ou tempo de acesso, que afetam a necessidade de um fator adicional. Consideramos que este é o melhor compromisso entre segurança e o utilizador, e encontramos isso em muitos tipos de empresas para oferecer ainda mais segurança sem limitar a facilidade de uso das ferramentas [4].

Por fim, a Autenticação sem palavra-passe (*Passwordless MFA*) é um modelo emergente, substituindo a palavra passe por combinações mais seguras de fatores, incluindo biometria e tokens criptográficos. Este tipo de dispositivo é promovido por empresas como Microsoft e Google, reduz bastante o risco que as palavras-passe representam e oferece aos utilizadores uma experiência de utilização mais eficiente [5].

Estes vários métodos de MFA mostram toda a gama que existe quando se trata de avançar na segurança digital. A seleção de um modelo apropriado varia dependendo do contexto de aplicação, nível de segurança exigido, bem como recursos [9].

Segundo dados recolhidos pela Statista, a aplicação de MFA nas empresas evidencia uma preferência clara por soluções baseadas em aplicações autenticadoras (57,8%), seguidas por códigos SMS (39,1%) e palavras-passe temporárias (OTP) (37,4%). Métodos baseados em hardware, como chaves de segurança físicas, representam cerca de 30% da adoção, enquanto o uso de endereços de e-mail secundários é menos comum (14,7%). Estes resultados demonstram que, embora a diversidade de métodos continue a crescer, existe uma tendência clara para o uso de tecnologias móveis e aplicações autenticadoras, que equilibram segurança e conveniência de utilização [11].

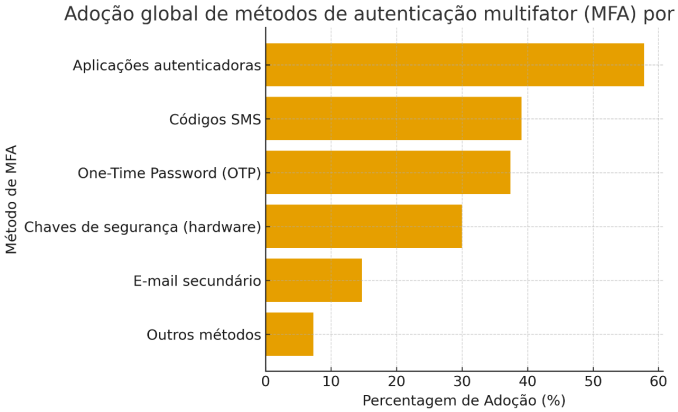

Figura 2. Adoção global de métodos de MFA
Nota. Adaptado de Statista, 2021, conforme citado em Scoop Market.us, 2025.
https://scoop.market.us/multi-factor-authentication-statistics

B. Comparação entre MFA e Autenticação de Um Único Fator

A Autenticação de Fator Único (SFA) é um método que utiliza apenas um tipo de verificação, geralmente uma palavra passe. Esta abordagem é simples e económica, o que a torna popular em diversos contextos. No entanto, as suas falhas de segurança são amplamente conhecidas. Técnicas como *phishing*, reutilização de palavras-passe e ataques de força bruta podem ser facilmente exploradas para obter acesso não autorizado, comprometendo a segurança de forma significativa [9].

Para ilustrar a vantagem matemática da MFA face à autenticação tradicional, podemos estimar o tempo necessário para quebrar uma palavra-passe por força bruta.

Equação 1 - Tempo Médio de Quebra por Força Bruta

$$T = \frac{N^L}{2R} \tag{1}$$

onde:

- N é o número de símbolos possíveis;
- L é o comprimento da palavra-passe;
- R é o número de tentativas por segundo;
- o fator $\frac{1}{2}$ reflete o valor médio esperado antes do sucesso.

Por exemplo, para uma palavra-passe com $N = 62$ (maiúsculas, minúsculas e dígitos), $L = 10$ e um atacante capaz de testar $R = 10^9$ combinações por segundo:

$$T = \frac{62^{10}}{2 \times 10^9} \approx 4.8 \times 10^7 \text{ segundos} \approx 1.5 \text{ anos.}$$

A adição de um segundo fator TOTP torna este cenário impraticável, pois a validade do código expira em segundos, impossibilitando ataques de tentativa massiva.

A força de uma palavra-passe pode ser medida pela sua entropia, que quantifica o número médio de bits de informação ou a imprevisibilidade associada à sua composição. A fórmula é dada por:

Equação 2 – Entropia de uma palavra-passe

$$H = \log_2(N^L) \tag{2}$$

onde:

- H é a entropia total (em bits);
- N é o número de símbolos possíveis (por exemplo, 62 para letras maiúsculas, minúsculas e dígitos);
- L é o comprimento da palavra-passe.

Por exemplo, uma palavra-passe de 8 caracteres com 62 símbolos possíveis tem:

$$H = \log_2(62^8) \approx 47.6 \text{ bits}$$

correspondendo a aproximadamente 2.18×10^{14} combinações possíveis. Aumentando o comprimento, obtêm-se valores exponencialmente superiores, conforme apresentado na Tabela I abaixo.

Tabela I
ENTROPIA E TEMPO MÉDIO DE QUEBRA PARA DIFERENTES COMPRIMENTOS DE PALAVRA-PASSE

Comprimento (L)	Entropia (H)	Combinações possíveis	Tempo médio (10^9 tent./s)
8	47,6 bits	2.18×10^{14}	$\approx 1,26$ dias
12	71,4 bits	3.23×10^{21}	$\approx 51\,117$ anos
16	95,3 bits	4.77×10^{28}	$\approx 7.55 \times 10^{11}$ anos

Estes resultados demonstram que o aumento do comprimento da palavra-passe melhora exponencialmente a segurança, tornando ataques de força bruta cada vez mais inviáveis. No entanto, a autenticação baseada num só fator continua vulnerável a diversos vetores, como ataques de dicionário, reutilização de credenciais, *phishing* ou fugas de dados.

Mesmo uma palavra-passe de 16 caracteres exigiria, em média, centenas de mil milhões de anos para ser quebrada por força bruta a 10^9 tentativas por segundo, mas ataques mais sofisticados, como os de dicionário, que exploram combinações comuns, padrões previsíveis e palavras reais, podem reduzir drasticamente o tempo necessário para comprometer uma

conta. Além disso, bastaria um vazamento ou ataque de engenharia social para expor as credenciais.

A autenticação multifator traz um nível adicional de proteção ao exigir pelo menos dois tipos diferentes de verificação, que podem envolver algo que o utilizador sabe, algo que o utilizador possui ou características pessoais, conforme ilustrado na Figura 3. Esta estratégia cria camadas de defesa, tornando muito mais difícil para um invasor obter acesso ao sistema, uma vez que seria necessário comprometer múltiplos fatores independentes [9].

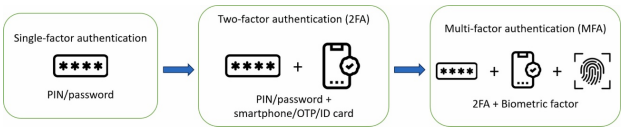

Figura 3. Tipos de autenticação. Adaptado de Tran-Truong et al. [10].

Embora a MFA exija um pouco mais de complexidade e investimento na implementação, proporciona um nível de segurança significativamente superior e é recomendada por entidades de referência como o NIST e a ENISA. Além disso, a MFA auxilia no cumprimento de exigências normativas como o GDPR, a ISO/IEC 27001 e a Diretiva PSD2, que incluem requisitos para autenticação reforçada [5].

C. TOTP

O algoritmo TOTP (*Time-based One-Time Password*) é um dos métodos mais comuns na autenticação de dois fatores. Baseia-se na geração de um código numérico temporário que muda a cada intervalo de tempo pré-definido, garantindo que o código só é válido por alguns segundos. O seu funcionamento é descrito matematicamente pela fórmula geral:

Equação 3 – Geração do código TOTP (RFC 6238)

$$\text{TOTP} = \text{Truncate}(\text{HMAC-SHA1}(K, T)) \tag{3}$$

onde:

- K é a chave secreta partilhada entre o servidor e o utilizador;
- HMAC-SHA1 é a função de autenticação por hash baseada em chave;
- T é o contador de tempo, calculado como:

$$T = \left\lfloor \frac{t - T_0}{X} \right\rfloor \tag{4}$$

sendo t o tempo atual (em segundos), T_0 o tempo inicial (*epoch*) e X o intervalo de validade (tipicamente 30 segundos).

O resultado é truncado e convertido num código numérico de seis dígitos, usado como segundo fator de autenticação. Esta abordagem é amplamente adotada em sistemas como o Google Authenticator e o Microsoft Authenticator devido à sua fiabilidade e independência de conectividade.

1) Robustez Matemática e Probabilidade de Colisão: A segurança do TOTP assenta na imprevisibilidade dos valores gerados. A probabilidade de um atacante adivinhar corretamente um código TOTP de seis dígitos é dada por:

Equação 4 – Probabilidade de acerto de um código TOTP

$$P_{TOTP} = \frac{1}{10^6} = 10^{-6} \tag{5}$$

Esta probabilidade é extremamente reduzida, e o código é temporário. Quando combinado com a autenticação por palavra-passe, resulta numa segurança composta, conforme já indicado na Equação (1). Assim, o modelo MFA baseado em TOTP aumenta a resiliência exponencial do sistema contra ataques de força bruta.

D. Vantagens da MFA

A MFA apresenta benefícios significativos, entre os quais se destaca o grande aprimoramento da segurança dos sistemas de informação. Mesmo que um fator seja comprometido, o atacante teria de contornar outro(s) fator(es) para obter acesso, reduzindo substancialmente a probabilidade de acesso não autorizado [9].

Matematicamente, a probabilidade de um atacante conseguir acesso indevido quando existem múltiplos fatores de autenticação é dada pela multiplicação das probabilidades de sucesso em cada fator individual:

Equação 5 – Probabilidade de acesso não autorizado com MFA

$$P_{MFA} = \prod_{i=1}^{n} P_i \tag{6}$$

onde:

- P_i representa a probabilidade de comprometer o i-ésimo fator de autenticação;
- n é o número total de fatores utilizados.

Por exemplo, se a probabilidade de adivinhar uma palavra-passe for $P_1 = 10^{-6}$ e a de violar um código TOTP for $P_2 = 10^{-3}$, o sistema multifator teria $P_{MFA} = 10^{-9}$. Este valor ilustra o aumento exponencial da segurança quando são usados fatores independentes.

Além disso, a MFA é reconhecida como um mecanismo essencial na proteção da identidade digital e dos dados pessoais, tanto na legislação da União Europeia (por exemplo, GDPR) quanto em normas internacionais como a ISO/IEC 27001. De acordo com Alves, Maia e Silva [2], a MFA é uma ferramenta indispensável na proteção contra ameaças de invasão e ataques de força bruta. Apesar de introduzir algum incómodo adicional aos utilizadores, os benefícios em termos de segurança são inegáveis, justificando a ampla adoção da MFA por instituições financeiras.

A validação da capacidade do sistema em utilizar mecanismos de autenticação avançados contribui ainda para a credibilidade e reputação das organizações, garantindo uma vantagem competitiva no mercado [4], [5].

E. Desafios da MFA

Embora existam vários aspetos positivos associados à adoção da MFA, estes também implicam responsabilidades técnicas e operacionais. Sem dúvida o maior desafio é a dificuldade técnica da sua implementação, principalmente se a MFA estiver a ser adicionada a sistemas mais antigos ou estiver a ser integrada num sistema já existente, implicando mais alterações.

O custo adicional é ainda outra das desvantagens deste mecanismo, já que as aplicações de MFA podem implicar custos de licenças, hardware ou software e de recursos humanos para suporte e manutenção [9].

A MFA pode ainda impactar a experiência do utilizador, já que passos adicionais no processo de autenticação podem traduzir-se em irritação ou atrasos no acesso, sobretudo se os fatores a considerar não forem adequadamente incorporados no fluxo de utilização [5].

A dependência tecnológica é também uma dificuldade, uma vez que a perda ou indisponibilidade do dispositivo autenticador pode impossibilitar um acesso legítimo. Por último, apesar da MFA ser muito eficaz, esta acaba por estar sujeita a técnicas de ataque mais sofisticadas, como o *SIM swapping* e *man-in-the-middle attack* pelo que deve ser complementada com outras medidas auxiliares de segurança [9].

F. Síntese Crítica

O exame dos artigos revistos permite destacar vários aspetos em comum. Em primeiro lugar, nota-se uma progressão óbvia da MFA tradicional para modelos adaptativos e baseados no contexto, onde o número e o tipo de fatores dependem do nível de risco aferido. Esta perspetiva, tratada por Aburbeian e Fernández-Veiga [1] e Podapati et al. [7], representa um compromisso entre segurança e comodidade, reduzindo o esforço imposto ao utilizador sem prejudicar o nível de proteção.

Em segundo lugar, ressalta a preocupação crescente com a usabilidade e as funcionalidades de recuperação de acesso. O trabalho de Amft et al. [3] evidencia que a segurança geral de um sistema não depende apenas da robustez técnica, mas também da consistência dos processos de suporte e de gestão de falhas. Para um projeto como o *SecureAccess*, isto significa que o design de um sistema MFA deve contemplar mecanismos de recuperação seguros e intuitivos, evitando brechas em resultado do comportamento humano.

Por outro lado, a tendência pela autenticação sem palavra passe (*passwordless*) representa o próximo passo evolutivo da MFA. Tal como exemplificado por Shukla et al. [8], prescindir do fator de conhecimento tradicional (palavra passe) em favor da biometria e de tokens criptográficos pode proporcionar uma experiência mais fluida e mitigar de forma significativa o risco de ataques de *phishing*. Todavia, estas soluções ainda enfrentam dificuldades técnicas e financeiras, nomeadamente na interoperabilidade dos equipamentos e na gestão segura dos dados biométricos.

G. Implicações para o Projeto SecureAccess

O sumário da literatura recente sustenta a pertinência da abordagem seguida neste projeto. A opção por um modelo baseado em palavrapasse + TOTP surge como uma proposta equilibrada entre factibilidade técnica, segurança e usabilidade, particularmente adequada a um protótipo académico. Esta dupla permite ilustrar, de forma concreta, os benefícios da MFA em contextos web, mantendo ao mesmo tempo uma simplicidade de implementação.

Por outro lado, as conclusões dos estudos revistos indicam potenciais rumos de evolução do sistema, como a introdução de uma autenticação adaptativa ou de meios biométricos complementares, estendendo o campo de aplicação e a solidez da solução. Por isso mesmo, a revisão de literatura confirma que a MFA não é apenas uma camada extra de de proteção, mas um elemento chave de arquiteturas modernas de identidade digital, devendo ser integrada de forma coordenada com políticas de segurança e experiência de utilizador.

IV. Discussão

A discussão encontrada na literatura científica sobre autenticação multifator deixa claro a quase unânime percepção da contribuição da mesma para o aumento da segurança cibernética. Os autores consultados, nomeadamente [9], [10], [1] e [7], reforçam a ideia de que o uso de múltiplos fatores de autenticação constitui um um avanço fundamental na mitigação de ataques baseados em credenciais roubadas, phishing e engenharia social. No entanto, estes mesmos trabalhos chamam também atenção para o facto de que a disseminação da MFA continua a esbarrar em várias dificuldades que associam ao custo de implementação, integração técnica e, principalmente, à usabilidade.

Com base nas conclusões retiradas da revisão da literatura, o projeto *SecureAccess* fica com a ideia de construir um sistema de autenticação multifator passível de aplicação em contextos web, que combine dois fatores distintos: um fator de conhecimento (palavra passe) e um fator de posse, assente em códigos temporais gerados por um algoritmo TOTP. Esta abordagem foi escolhida pela sua comprovada eficácia e pela simplicidade de integração, sendo uma das mais frequentes e divulgadas atualmente em organizações e no meio académico [4], [5].

Com a implementação do protótipo em Flask pretende-se mostrar na prática as vantagens da MFA face à utilização tradicional da palavra-passe apenas enquanto fator de autenticação. Espera-se que a introdução de um segundo fator diminua drasticamente as hipóteses de um ataque de força bruta ou de reutilização de credenciais ser bem sucedido, aumentando assim a confiança e segurança da sessão de login. Além disso, será avaliado o impacto que esta medida tem na experiência do utilizador, questão amplamente debatida por [3], que destacam a necessidade de equilibrar segurança e conveniência em sistemas MFA.

Outro ponto importante da vertente prática incidirá sobre a possibilidade da solução escalar e adaptar-se, avaliando assim o quão viável pode ser a extensão da solução a

outras tecnologias, como autenticação biométrica ou chaves criptográficas FIDO2/WebAuthn. Estes métodos representam o próximo salto evolutivo da MFA, ao apontarem níveis de segurança mais robustos e reduzirem a dependência das palavras passe, regularmente apontadas como o elo mais fraco nos esquemas de autenticação [9].

Em suma, esta reflexão permite antecipar que o projeto *SecureAccess* pode sinalizar, de uma perspetiva académica e prática, como a adoção de MFA também pode ser feita de forma acessível, eficaz e em conformidade com as melhores práticas internacionais de segurança. É de esperar que o projeto *SecureAccess* formente uma diminuição significativa da exposição a acessos indevidos e que os resultados apurados na próxima fase venham a corroborar os benefícios listados na literatura, enaltecendo o papel da autenticação multifator como um elemento não apenas necessário mas crucial na salvaguarda dos sistemas web e na consolidação de uma sociedade digital mais segura.

A. Ecrãs e fluxo do Protótipo

As figuras abaixo mostram o fluxo real de interação do utilizador, desde o registo à MFA, complementando a descrição funcional dada na Secção da Implementação.

1) Ecrã Inicial de Login: O ecrã de login é a ”porta”da aplicação. Neste, o utilizador deve fornecer o seu nome de utilizador e palavra passe. Se as credenciais forem válidas, a aplicação verifica automaticamente se o utilizador já possui a MFA ativada. Se assim for, o utilizador é levado para o segundo fator de autenticação; caso contrário, é iniciado o processo de configuração da MFA.

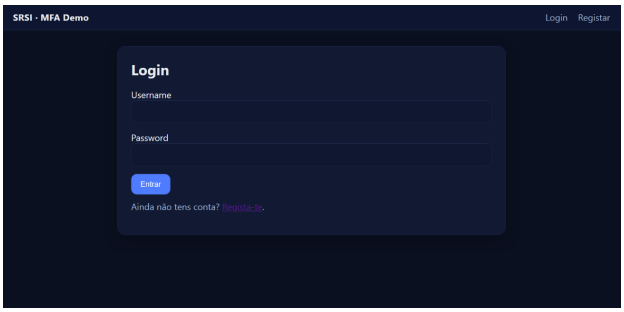

Figura 4. Ecrã inicial de login

2) Ecrã de Registo: O ecrã de registo permite a criação de novas contas no sistema. Os dados introduzidos são validados e armazenados na base de dados SQLite, com a palavra passe protegida através de hashing. Após o registo, o utilizador prossegue para o primeiro login, sendo posteriormente encaminhado para a configuração da MFA.

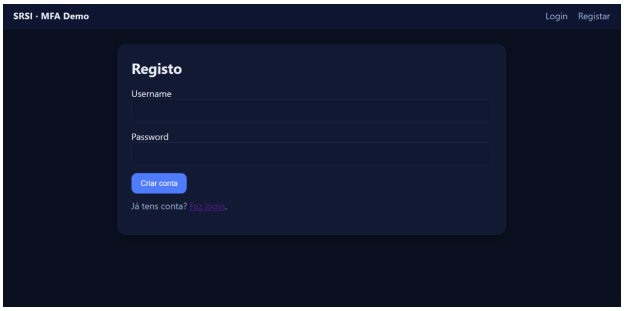

Figura 5. Ecrã de registo de utilizador

3) Ecrã de Configuração do MFA (QR Code): Na primeira vez que iniciar sessão, o programa cria automaticamente um segredo TOTP para o utilizador (encriptado antes de ficar guardado na base de dados SQLite). Este segredo é convertido para um *QR Code*, mostrado no ecrã, permitindo ao utilizador adicioná-lo a uma app autenticadora de sua preferência (exemplo: Google Authenticator ou Authy). A dita app fica assim a gerar códigos de utilização única TOTP com um período de validade de 30 segundos, conforme referido na RFC 6238.

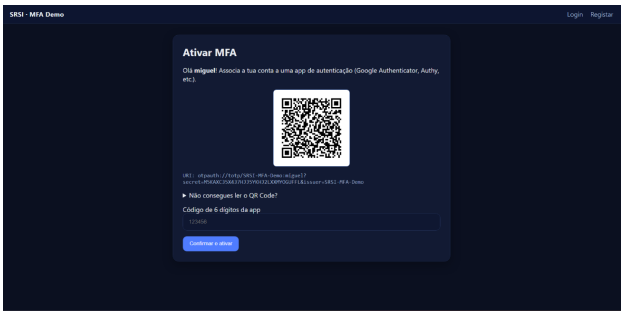

Figura 6. Ecrã de configuração do MFA (QR Code)

4) Ecrã de Validação do Código TOTP: Depois de ler o código QR, o utilizador insere o código TOTP produzido pela sua aplicação autenticadora. Este é verificado tendo em conta a chave secreta que previamente cifrada e guardada. Se a verificação for bem sucedida, o processo de ativação da MFA fica concluído.

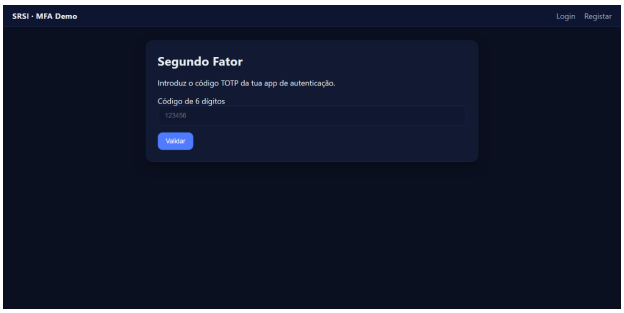

Figura 7. Ecrã de validação do código TOTP

5) Ecrã de Erro ou Código Inválido: Caso o código TOTP se encontre errado ou tenha expirado, o sistema apresenta uma

mensagem de erro clara, permitindo nova tentativa. Esta abordagem está alinhada com as boas práticas de usabilidade em segurança, evitando frustração e garantindo *feedback* imediato ao utilizador.

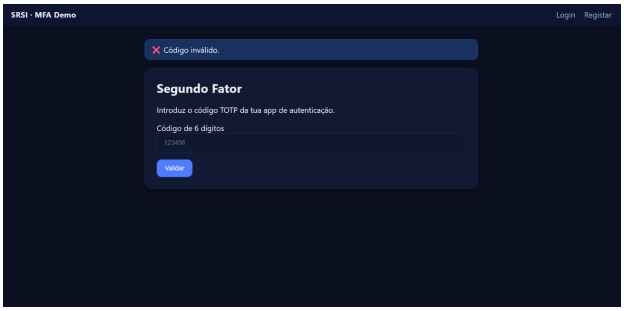

Figura 8. Ecrã de erro ou código inválido

6) Ecrã de Acesso Concedido: Depois da verificação do segundo fator ter sido feita, o utilizador está autenticado com sucesso e é redirecionado para o *dashboard*. Esta página ilustra o estado da MFA e assinala o fim do processo de autenticação, proporcionando um acesso seguro e melhorado à aplicação.

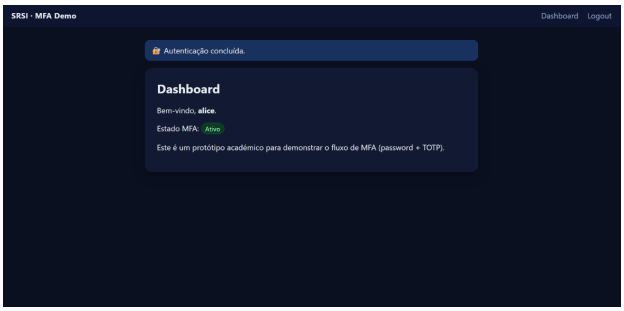

Figura 9. Ecrã de acesso concedido

B. Guia de Execução do Protótipo SecureAccess

Esta secção descreve os procedimentos necessários para instalar e executar o protótipo desenvolvido em Flask, permitindo a sua reprodução em qualquer máquina com suporte para Python. As instruções seguintes refletem a configuração utilizada na fase prática do projeto.

1) Requisitos: Para a execução do protótipo são necessários:

- Python 3.11 ou superior;
- (Opcional) Ambiente virtual *Python venv*;
- Sistema operativo Windows, Linux ou macOS.

2) Instalação do Ambiente: Com o terminal aberto na raiz do projeto, deve ser criado e ativado um ambiente virtual:

```
python -m venv .venv

# Windows:
.venv\Scripts\activate
# Linux/Mac:
source .venv/bin/activate
```

De seguida, instalam-se as dependências necessárias:

```
pip install -r requirements.txt
```

3) Configuração das Variáveis de Ambiente: O protótipo utiliza o ficheiro `.env`, carregado automaticamente pela biblioteca `python-dotenv`. Deve ser criado (ou alterado) o ficheiro `.env` na raiz do projeto com o seguinte conteúdo:

```
FLASK_SECRET_KEY=uma-chave-forte-aqui
MFA_ENC_KEY=A_TUA_CHAVE_GERADA_AQUI
MFA_DB_PATH=mfa.db
```

A chave `MFA_ENC_KEY`, utilizada para encriptar os segredos TOTP, pode ser gerada através do seguinte comando:

```
python
from cryptography.fernet import Fernet
print(Fernet.generate_key().decode())
exit()
```

4) Execução do Protótipo: Antes de iniciar a aplicação, deve garantir-se que o ambiente virtual se encontra ativo:

```
# Windows:
.venv\Scripts\activate
# Linux/Mac:
source .venv/bin/activate
```

A aplicação é então executada com:

```
python app.py
```

O servidor ficará disponível em:

- **Localmente:** `http://127.0.0.1:5000`
- **Em rede (LAN):** `http://<IP_do_servidor>:5000`

Esta opção permite a interação de vários clientes com a mesma instância, sendo essencial para os testes experimentais apresentados mais abaixo.

5) Fluxo de Utilização: O fluxo de utilização da aplicação é o seguinte:

1) Aceder a `/register` para criar um novo utilizador.
2) Efetuar login em `/login` com as credenciais criadas.
3) No primeiro acesso, o utilizador é redirecionado para `/setup_mfa`, onde deve:
   - Ler o QR Code com o Google Authenticator (ou equivalente);
   - Introduzir o código TOTP de 6 dígitos.
4) Nos acessos seguintes, o segundo fator é solicitado através de `/mfa`.
5) Após validação, o utilizador acede ao *dashboard*.

6) Estrutura do Projeto:

```
mfa_flask_prototype/

 .env
 app.py
 requirements.txt
 README.md
```

```
templates/
   base.html
   login.html
   register.html
   setup_mfa.html
   mfa.html
   dashboard.html

static/
    styles.css
```

7) Considerações de Segurança:

- A `SECRET_KEY` e a `MFA_ENC_KEY` devem ser únicas e fortes.
- As palavras-passe são armazenadas com *hash* seguro.
- Os segredos TOTP são encriptados com *Fernet (AES-128)*.
- O ficheiro `.env` não deve ser versionado (`.gitignore`).
- Em ambiente de produção, recomenda-se HTTPS, CSRF protection e rate-limiting.

8) Testes Rápidos:

- Introduzir códigos TOTP errados — autenticação deve falhar.
- **Teste 1**: dois clientes tentam registar o mesmo username — apenas um deve ser aceite.
- **Teste 2**: dois utilizadores ativam MFA em simultâneo — QR Codes, segredos e TOTP distintos.
- **Teste 3**: verificação de encriptação — o campo `totp_secret` deve conter valores iniciados por `gAAAA...`

C. Testes Práticos e Validação Experimental

Para validar o correto funcionamento do protótipo *SecureAccess*, foram realizados testes práticos em ambiente real, envolvendo múltiplos utilizadores e dispositivos distintos. O objetivo consistiu em verificar a robustez do sistema perante situações de concorrência e garantir que a implementação da Autenticação Multifator (MFA) se comporta de forma consistente com o esperado.

1) Ambiente de Testes: Os testes foram conduzidos utilizando três computadores portáteis, todos ligados ao mesmo ponto de acesso através de um *hotspot* móvel. Um dos computadores atuou como servidor, executando a aplicação Flask com suporte a ligações externas, enquanto os outros dois funcionaram como clientes, acedendo à aplicação via navegador através do endereço IP do servidor.

Esta configuração permite simular um cenário realista de utilização distribuída, onde múltiplos utilizadores interagem simultaneamente com o sistema através da rede.

2) Teste 1: Registos Simultâneos com o Mesmo Username: O primeiro teste teve como objetivo verificar a integridade do processo de registo perante tentativas concorrentes de criação de contas com o mesmo identificador. Dois clientes tentaram registar-se com o mesmo *username* de forma simultânea, enquanto o servidor processava ambos os pedidos.

- **Resultado esperado**: apenas um dos registos deve ser aceite; o segundo deve falhar, apresentando a mensagem *"Esse username já existe"*.
- **Resultado obtido**: o sistema comportou-se conforme projetado. Um dos clientes conseguiu registar-se com sucesso, enquanto o outro recebeu a mensagem de erro correspondente, conforme ilustrado nas Figuras 10, 11 e 12.

Este comportamento é garantido ao nível da base de dados, através da restrição `UNIQUE` aplicada ao campo `username`, bem como pelo tratamento da exceção `IntegrityError` na camada de aplicação.

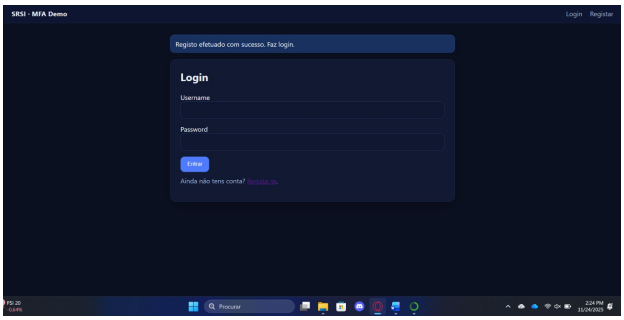

Figura 10. Teste 1 – Cliente 1: registo bem-sucedido

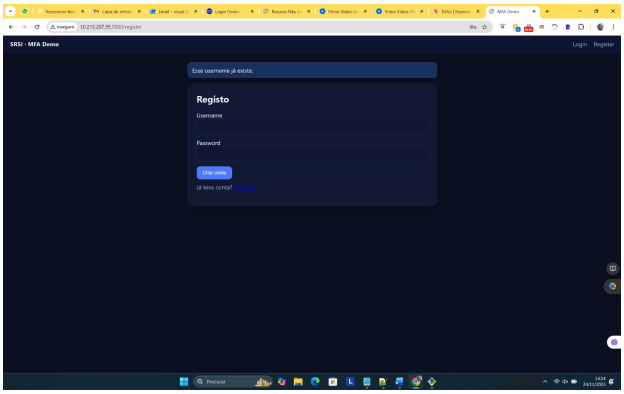

Figura 11. Teste 1 – Cliente 2: tentativa de registo rejeitada

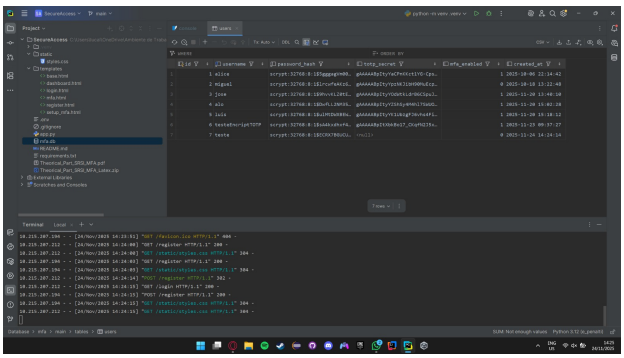

Figura 12. Teste 1 – Vista do servidor durante pedidos concorrentes

3) Teste 2: Ativação Simultânea da MFA: O segundo teste visou verificar a independência e aleatoriedade dos segredos TOTP atribuídos a cada utilizador. Dois clientes iniciaram sessão com contas distintas e procederam à ativação da MFA de forma simultânea.

- **Resultado esperado**: os dois utilizadores devem receber QR Codes diferentes, contendo segredos TOTP distintos, conduzindo à geração de códigos TOTP diferentes no mesmo período temporal.
- **Resultado obtido**: ambos QR Codes gerados apresentaram URIs e segredos base32 independentes, resultando em códigos TOTP divergentes, tal como previsto pelo algoritmo RFC 6238. As Figuras 13, 14 e 15 ilustram o processo.

Este resultado confirma que a aplicação gera corretamente um segredo aleatório para cada utilizador (*pyotp.random_base32()*), posteriormente encriptado antes de ser armazenado na base de dados, garantindo segurança e isolamento entre contas.

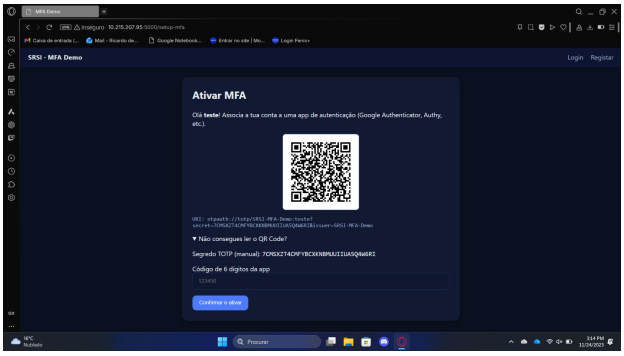

Figura 13. Teste 2 – Cliente 1: QR Code e URI TOTP

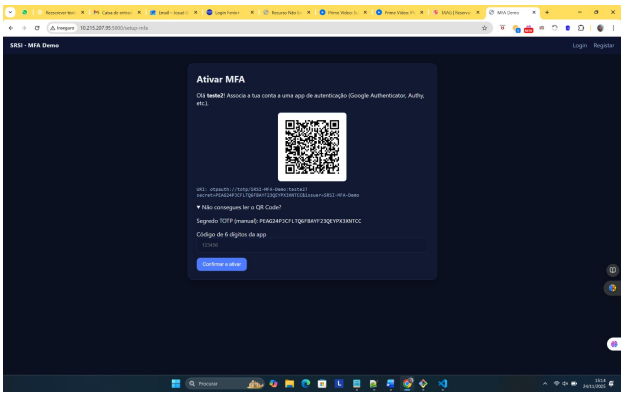

Figura 14. Teste 2 – Cliente 2: QR Code e URI TOTP

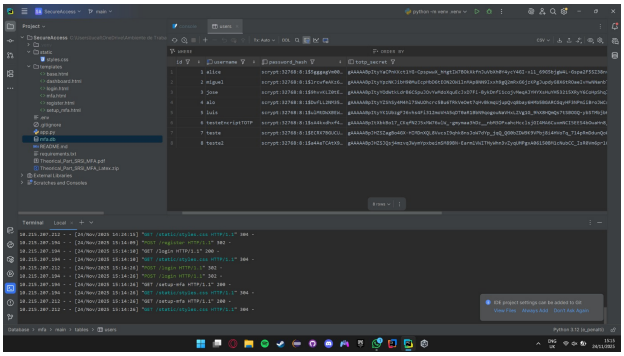

Figura 15. Teste 2 – Consola e base de dados do servidor durante a ativação simultânea

V. Conclusões

O conhecimento teórico adquirido ao longo deste trabalho permitiu ainda aprofundar a perceção da relevância de uma autenticação multifator para a segurança dos sistemas de informação. Através da revisão sistemática da literatura, percebeu-se que a MFA é frequentemente vista como uma ferramenta fundamental para a prevenção de ataques baseados no roubo de credenciais, representando assim um dos alicerces da cibersegurança atual [9].

Esta perspetiva é corroborada por estudos recentes [1], [7], [8] que evidenciam a evolução da MFA para modelos adaptativos e baseados em risco. Os estudos analisados indicam que a combinação de diferentes fatores de autenticação, conhecimento, posse e inerência, oferecem uma proteção significativamente mais robusta do que os sistemas baseados num único fator.

Entre as abordagens existentes, a autenticação com base em TOTP destaca-se pela sua simplicidade de implementação, compatibilidade com tecnologias existentes e eficácia comprovada na mitigação de ataques comuns, como *phishing* ou *credential stuffing* [4], [5].

Com a implementação do protótipo em Flask, foi possível demonstrar na prática o funcionamento da MFA baseada em palavra-passe e códigos TOTP. Os testes realizados confirmaram várias das tendências identificadas na revisão teórica, nomeadamente a eficácia da MFA na mitigação de ataques baseados em credenciais comprometidas e a sua robustez contra tentativas simultâneas de acesso.

Os resultados experimentais mostraram que a utilização de um segundo fator reduz substancialmente a probabilidade de acesso indevido, validando empiricamente os benefícios previstos pela literatura.

A MFA, quando bem concebida, não deve ser vista apenas como uma camada adicional de segurança, mas como parte integrante de uma estratégia global de gestão de identidades digitais. Em suma, este relatório representa a primeira etapa de um trabalho mais amplo que combina investigação científica e aplicação prática.

As conclusões aqui apresentadas servirão de base para a fase seguinte de desenvolvimento e avaliação experimental, onde será possível validar empiricamente os benefícios esperados e

propor melhorias que possam aproximar ainda mais a MFA das necessidades reais dos utilizadores e das organizações.

VI. Trabalhos Futuros

Com a implementação prática do protótipo *SecureAccess*, foi possível validar experimentalmente os conceitos analisados na revisão teórica, nomeadamente a eficácia da autenticação multifator (MFA) baseada em palavra-passe e códigos TOTP. Apesar da solução desenvolvida cumprir os objetivos definidos, existem diversas oportunidades de evolução que poderão reforçar a segurança, escalabilidade e usabilidade do sistema.

Assim, propõem-se os seguintes trabalhos futuros:

- **Reforço da encriptação de segredos TOTP**: embora a solução atual utilize encriptação simétrica com *Fernet*, poderá ser substituída por mecanismos de gestão de chaves mais avançados (como HashiCorp Vault, AWS KMS ou módulos HSM) para ambientes empresariais.
- **Integração de métodos biométricos**: apoio a fatores de inerência, como impressão digital, reconhecimento facial ou voz, garantindo níveis de autenticação mais elevados.
- **Suporte para chaves FIDO2/WebAuthn**: permitir autenticação resistente a *phishing*, reduzindo a dependência de palavras-passe e aumentando a robustez do processo.
- **Autenticação adaptativa baseada em risco**: ajustar dinamicamente os fatores necessários com base em contexto, localização, comportamento ou dispositivo utilizado.
- **Implementação de mecanismos de recuperação segura da MFA**: criação de processos robustos para recuperação de acesso em caso de perda do dispositivo autenticador.
- **Rate-limiting e deteção de anomalias**: mitigação de ataques de força bruta, *credential stuffing* e tentativas repetidas de TOTP.
- **Registo de eventos e auditoria**: criação de logs estruturados sobre tentativas de login, ativações de MFA e falhas, podendo alimentar dashboards de monitorização.
- **Avaliação de desempenho e testes de usabilidade**: estudos formais com utilizadores, recolhendo métricas de satisfação, tempo de autenticação e impacto da MFA na experiência global.

Estas direções de evolução reforçam o potencial do *SecureAccess* como base para investigação contínua e demonstram a aplicabilidade da MFA em contextos académicos e empresariais mais exigentes. O código-fonte atualizado, bem como a documentação associada ao protótipo, encontra-se alojado no repositório GitHub do projeto, garantindo reprodutibilidade e continuidade de desenvolvimento.

SecureAccess.

Repositório disponível em: https://github.com/ricardo-ourelo/SecureAccess

Referências

[1] A. H. M. Aburbeian and M. Fernández-Veiga, "Secure Internet Financial Transactions: A Framework Integrating Multi-Factor Authentication and Machine Learning,"*AI (Switzerland)*, vol. 5, no. 1, pp. 177–194, 2024. [Online]. Available: https://doi.org/10.3390/ai5010010

[2] V. F. Alves, M. V. da Silva, and T. de O. Maia, "O uso de autenticação multi-fator (MFA) e sua importância / The use of multi-factor authentication (MFA) and its importance,"in *Congresso de Segurança da Informação das Fatec*, 2023. [Online]. Available: https://fatecseg.fatecourinhos.edu.br/index.php/fatecseg/article/view/115/34

[3] S. Amft, S. Höltervennhoff, N. Huaman, A. Krause, L. Simko, Y. Acar, and S. Fahl, "'We've Disabled MFA for You': An Evaluation of the Security and Usability of Multi-Factor Authentication Recovery Deployments,"in *Proceedings of the 2023 ACM SIGSAC Conference on Computer and Communications Security (CCS 2023)*, pp. 3138–3152. [Online]. Available: https://doi.org/10.1145/3576915.3623180

[4] CISCO, "What is multi-factor authentication (MFA)?", 2025. [Online]. Available: https://www.cisco.com/site/us/en/learn/topics/security/what-is-multi-factor-authentication-mfa.html#tabs-35d568e0ff-item-4bd7dc8124-tab

[5] Microsoft Entra, "Microsoft Entra authentication documentation,"2025. [Online]. Available: https://learn.microsoft.com/en-us/entra/identity/authentication/concept-mfa-howitworks

[6] S. Keshav and D. R. Cheriton, "How to Read a Paper,"2007. [Online]. Available: http://ccr.sigcomm.org/online/files/p83-keshavA.pdf

[7] V. H. Podapati, D. Nigam, and S. Das, "SoK: A Systematic Review of Context- and Behavior-Aware Adaptive Authentication in Mobile Environments,"2025. [Online]. Available: http://arxiv.org/abs/2507.21101

[8] S. Shukla, G. Varshney, S. Singh, and S. Goel, "A Passwordless MFA Utilizing Biometrics, Proximity and Contactless Communication,"2024. [Online]. Available: http://arxiv.org/abs/2406.09000

[9] D. Temoshok, J. L. Fenton, Y.-Y. Choong, N. Lefkovitz, A. Regenscheid, R. Galluzzo, and J. P. Richer, *Digital Identity Guidelines: NIST Special Publication 800-63B-4*, National Institute of Standards and Technology, 2025. [Online]. Available: https://doi.org/10.6028/NIST.SP.800-63B-4

[10] P. T. Tran-Truong, M. Q. Pham, H. X. Son, D. L. T. Nguyen, M. B. Nguyen, K. L. Tran, L. C. P. Van, K. T. Le, K. H. Vo, N. N. T. Kim, T. M. Nguyen, and A. T. Nguyen, "A systematic review of multi-factor authentication in digital payment systems: NIST standards alignment and industry implementation analysis,"*Journal of Systems Architecture*, vol. 162, 2025. [Online]. Available: https://doi.org/10.1016/j.sysarc.2025.103402

[11] Statista, "Multi-Factor Authentication (MFA) Statistics and Trends 2025,"*Scoop Market.us*, 2025. [Online]. Available: https://scoop.market.us/multi-factor-authentication-statistics